

Universidade Presbiteriana Mackenzie
Inteligência Artificial

Agente Especialista em GRC

Um assistente conversacional baseado em RAG e LLM local para consulta ao
framework COSO ERM 2017

Relatório do Projeto – Primeiro Bimestre (N1)

Guilherme Martins Silva	RA 10417140
Enzo Ribeiro	RA 10418262
Pedro Nogueira Ribeiro	RA 10324924

Repositório do projeto: https://github.com/gu1m/ai_lab_mack

São Paulo, 2026

1. Resumo

Este relatório apresenta a proposta do projeto *Agente Especialista em GRC*, um assistente conversacional a ser desenvolvido para o domínio de Governança, Riscos e Compliance (GRC), com foco no framework *COSO Enterprise Risk Management – Integrating with Strategy and Performance* (COSO, 2017). O sistema proposto combinará um modelo de linguagem (LLM) executado localmente com uma arquitetura de Geração Aumentada por Recuperação (Retrieval-Augmented Generation – RAG) (LEWIS et al., 2020), de modo a fundamentar as respostas em trechos reais do documento-fonte, reduzindo o risco de alucinações e permitindo a citação da origem de cada informação. Como o corpus do projeto é um documento textual extenso (não um dataframe tabular), a etapa de análise exploratória é conduzida com técnicas de Processamento de Linguagem Natural (PLN): estatísticas de corpus, limpeza e normalização textual, análise de frequência de termos, ponderação TF-IDF (SALTON; BUCKLEY, 1988) e extração da estrutura temática do framework (5 componentes e 20 princípios). Os resultados desta primeira etapa confirmam a viabilidade do corpus para alimentar o pipeline de RAG e orientam decisões de preparação de dados (segmentação, remoção de ruído de extração de PDF e deduplicação) detalhadas nas seções seguintes.

2. Introdução

2.1 Contextualização

A adoção de modelos de linguagem de grande escala (LLMs) por organizações vem crescendo rapidamente, tanto para automação de tarefas quanto para apoio à decisão. Em paralelo, o ambiente regulatório e de gestão de riscos corporativos tem se tornado mais complexo, com a convivência de múltiplos frameworks e normas – como o COSO ERM (COSO, 2017), a resolução europeia DORA, normas do Banco Central do Brasil e padrões como COBIT e ITIL – que juntos somam centenas de páginas de conteúdo técnico. Nesse cenário, surge a oportunidade de aplicar técnicas de RAG (LEWIS et al., 2020) para construir assistentes especializados capazes de responder perguntas sobre esses frameworks com base direta no texto oficial, em vez de depender apenas do conhecimento paramétrico, potencialmente desatualizado ou impreciso, de um LLM genérico.

2.2 Justificativa

Profissionais de GRC frequentemente precisam localizar rapidamente um princípio, definição ou orientação específica dentro de documentos extensos, tarefa manual, lenta e sujeita a erro de interpretação. Assistentes de LLM de propósito geral (ex.: ChatGPT) apresentam duas limitações relevantes para esse cenário: (i) risco de alucinação ao responder sobre conteúdo específico de um framework, por não terem acesso direto e citável ao documento-fonte; e (ii) a necessidade de enviar dados a uma API externa, o que pode ser inadequado quando a organização deseja tratar informações internas de risco com maior controle de privacidade. O projeto se justifica, portanto, por propor uma solução que mantém o processamento local, fundamenta as respostas em fontes rastreáveis e estima um indicador de confiança (perplexidade) para cada resposta gerada.

2.3 Objetivo

Desenvolver um agente conversacional especialista em GRC, fundamentado em RAG sobre o corpus do COSO ERM 2017, que será capaz de: (a) recuperar e re-ranquear os trechos mais relevantes do documento para uma dada pergunta; (b) gerar respostas em linguagem natural citando a fonte de cada trecho utilizado; (c) manter memória conversacional de curto/médio prazo para perguntas de acompanhamento; e (d) estimar a confiança da resposta gerada por meio do cálculo de perplexidade. Neste primeiro bimestre, o objetivo específico é consolidar a proposta, descrever o corpus que será utilizado e realizar sua análise exploratória e preparação inicial em Python.

2.4 Opção do projeto

Dentre as opções de projeto oferecidas na disciplina, o grupo optou pela **Opção API ChatGPT**, categoria destinada a aplicações construídas sobre modelos de linguagem generativos. Em vez de utilizar a API comercial do ChatGPT, o grupo optou por substituí-la por um modelo aberto a ser executado localmente (Meta Llama 3.2 3B Instruct, quantizado em 4 bits), que será integrado a um pipeline completo de RAG. Essa adaptação, dentro da mesma categoria de projeto (aplicação baseada em LLM generativo), é motivada pela natureza sensível de dados de risco e compliance, pelo interesse do grupo em implementar e controlar cada etapa do pipeline (recuperação, re-ranking, geração e avaliação) e por eliminar custos recorrentes de uso de API paga durante o desenvolvimento e os testes.

3. Descrição do Problema

Documentos normativos de GRC, como o COSO ERM 2017, são extensos, escritos em linguagem técnica e organizados em uma hierarquia de componentes e princípios que nem sempre é trivial de navegar. A consulta manual demanda tempo de especialistas e pode levar a interpretações divergentes do mesmo trecho normativo. Ferramentas de busca por palavra-chave (Ctrl+F) tampouco resolvem bem o problema, pois não lidam com sinônimos, parafraseamento ou perguntas compostas.

O problema central que este projeto busca resolver é: *como fornecer respostas rápidas, corretas e rastreáveis a perguntas em linguagem natural sobre um framework de GRC, preservando a privacidade dos dados envolvidos e minimizando o risco de informações incorretas geradas pelo modelo?* A resposta proposta combinará recuperação de informação (para ancorar o conteúdo no texto oficial), re-ranking semântico (para priorizar os trechos mais relevantes) e geração condicionada ao contexto recuperado (para reduzir alucinações), com execução local do modelo de linguagem.

4. Aspectos Éticos do Uso de IA e Responsabilidade no Desenvolvimento

Alucinação e confiabilidade. LLMs podem gerar informações plausíveis, porém incorretas (Jl et al., 2023). Em um domínio normativo como GRC, uma resposta equivocada sobre um princípio do COSO ERM pode levar a decisões de risco mal fundamentadas. Por isso, o sistema está sendo projetado para restringir explicitamente o modelo a responder com base apenas no contexto recuperado (evitando que ele 'invente' fatos fora do contexto fornecido), citar a fonte de cada trecho utilizado e calcular a perplexidade da resposta como um indicador auxiliar (não definitivo) de confiança.

Privacidade e uso de dados. A opção por executar o LLM de forma local (em vez de uma API externa) é uma escolha deliberada de projeto para evitar o envio de perguntas e, potencialmente, de dados sensíveis de risco corporativo a terceiros. Essa decisão dialoga diretamente com princípios de privacidade por concepção (*privacy by design*) discutidos na literatura de ética em IA (FLORIDI; COWLS, 2019) e com a Lei Geral de Proteção de Dados brasileira, ainda que o corpus atual não contenha dados pessoais.

Direitos autorais e uso responsável de fontes. O documento COSO ERM 2017 é protegido por direitos autorais ('*All Rights Reserved*', conforme nota no próprio documento). O uso do texto neste projeto se limita a fins educacionais e de indexação interna para fundamentar respostas (RAG), sem redistribuição do conteúdo integral, o que é coerente com um uso responsável e transformador do material.

Papel humano e responsabilidade final. O agente está sendo concebido como uma ferramenta de apoio, não como um substituto do julgamento profissional. Decisões de risco e compliance devem permanecer sob responsabilidade de especialistas humanos (*human-in-the-loop*), cabendo ao sistema acelerar a consulta e apresentar evidências, não decidir. Essa distinção segue recomendações de órgãos como a UNESCO (2021) sobre supervisão humana de sistemas de IA.

Viés e limitações do modelo. O modelo de linguagem que será utilizado (Llama 3.2) é de propósito geral e não passará por ajuste fino (*fine-tuning*) específico para o domínio de GRC, podendo refletir vieses ou lacunas de seus dados de treinamento originais. A mitigação planejada é restringir a geração ao contexto recuperado do corpus e sinalizar explicitamente quando não houver informação suficiente para responder.

5. Dataset: Corpus COSO ERM, Análise Exploratória e Preparação dos Dados

5.1 Origem e descrição do corpus

O projeto não utiliza um dataframe tabular como fonte primária de dados, e sim um corpus textual: o documento oficial *Enterprise Risk Management – Integrating with Strategy and Performance* (COSO, 2017), publicado pelo Committee of Sponsoring Organizations of the Treadway Commission (eBook ISBN 978-1-94549-886-2). O documento é público e não contém dados pessoais, dispensando anonimização. Para esta etapa do projeto, o texto do documento foi extraído do PDF oficial para formato .txt, sendo esse arquivo a base utilizada na análise exploratória descrita a seguir e, posteriormente, na indexação do agente de RAG a ser desenvolvido.

Estruturalmente, o documento se organiza em três grandes blocos (Executive Summary, Framework e Appendices) e, dentro do Framework, em 5 componentes e 20 princípios de gestão de riscos corporativos. A Tabela 1 lista os 20 princípios identificados automaticamente a partir do texto (ver seção 5.3).

5.2 Preparação dos dados (limpeza e normalização)

Antes de qualquer análise, o texto extraído do PDF original foi inspecionado e revelou dois problemas típicos de conversão PDF-para-texto:

- Marcadores residuais da paginação original (a palavra isolada break em 52 linhas), que não fazem parte do conteúdo textual e foram removidos por expressão regular.
- Perda do ligature tipográfico 'fi' durante a extração do PDF: a sequência de caracteres 'fi' é sistematicamente substituída por um espaço em branco (ex.: 'Certified' aparece como 'Certi ed'; 'Defines' como 'De nes'; 'Identifies' como 'Identi es').

Para corrigir o segundo problema sem introduzir falsos positivos, foi implementada uma heurística em Python que, para cada par de palavras separadas por um único espaço, testa se a fusão com 'fi' inserido forma uma palavra válida do dicionário inglês (corpus `nltk.words`, com tratamento de flexões simples de plural/gerúndio, dado que o corpus não cobre todas as formas conjugadas) e, ao mesmo tempo, confirma que a versão sem espaço NÃO é ela própria uma palavra válida, evitando fundir pares que apenas coincidem por acaso. Um trecho simplificado dessa rotina é reproduzido a seguir:

```
def fix_broken_fi_ligature(text, vocab):
    def repl(m):
        left, right = m.group(1), m.group(2)
        candidate = f'{left}fi{right}'
        if known(candidate) and not known(left + right):
            return candidate
        return m.group(0)
    return re.sub(r'\b([A-Za-z]{2,})[ ]([a-z]{1,6})\b', repl, text)
```

A aplicação dessa rotina corrigiu **338 ocorrências** do ligature quebrado no corpus, incluindo os títulos de diversos princípios do framework (ex.: Princípio 3 – 'Defines Desired Culture'; Princípio 10 – 'Identifies Risk'), que são justamente os termos estruturais mais relevantes para a extração apresentada na Tabela 1. Após a limpeza, também foram normalizados espaços em branco redundantes e quebras de linha excessivas, preparando o texto para as etapas de tokenização e

vetorização.

5.3 Análise exploratória (estatísticas de PLN)

Métrica	Valor
Caracteres (após limpeza)	366.662
Sentenças	2.492
Tokens (total)	61.241
Tokens alfabéticos	52.919
Tamanho do vocabulário (único)	3.879
Diversidade léxica (TTR)	0.0733
Média de palavras por sentença	24.58
Média de caracteres por palavra	5.58

A baixa diversidade léxica (TTR) é esperada em documentos técnicos longos, que reutilizam o mesmo vocabulário especializado repetidamente. Essa característica reforça a adequação de uma abordagem de recuperação semântica (embeddings) em vez de busca literal por palavras-chave.

A análise de frequência de termos (após remoção de *stopwords* em inglês) e a ponderação TF-IDF por parágrafo (SALTON; BUCKLEY, 1988) confirmam a centralidade dos conceitos de risco, estratégia, objetivos e governança corporativa no corpus, conforme ilustrado nas Figuras 1 e 2.

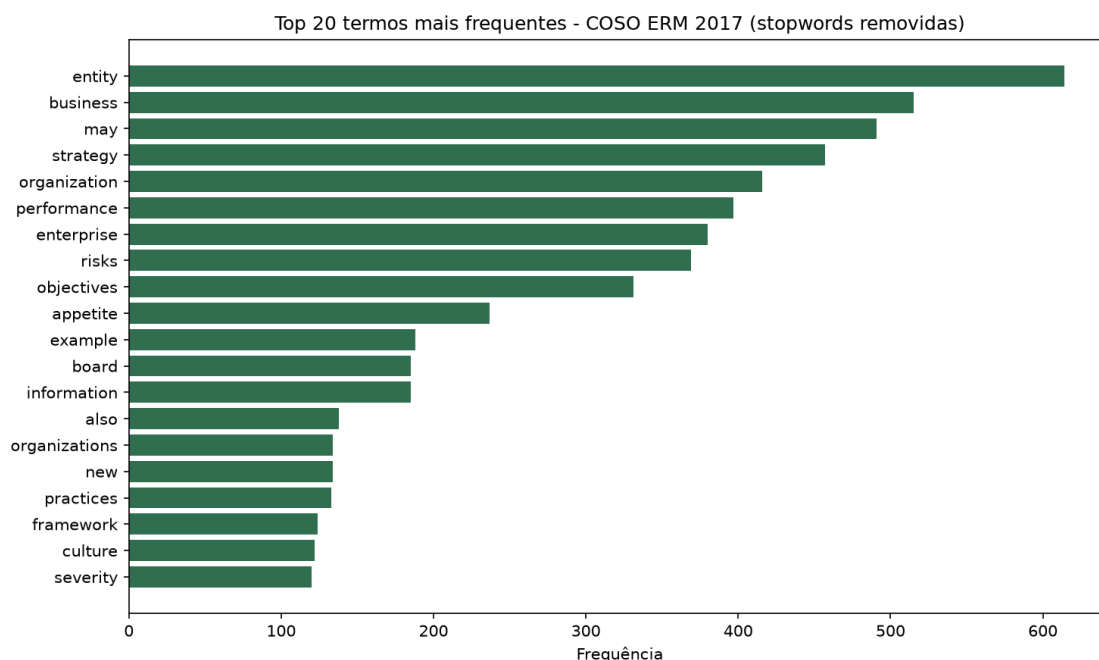


Figura 1 – Top 20 termos mais frequentes no corpus COSO ERM 2017 (stopwords removidas).

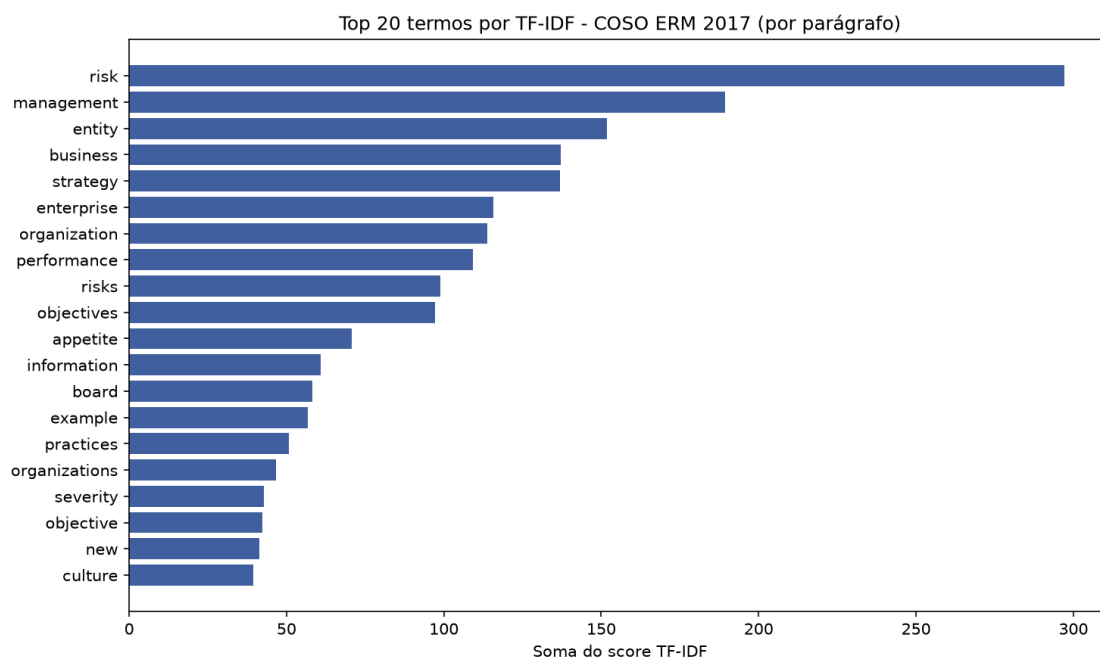


Figura 2 – Top 20 termos por score TF-IDF agregado, calculado por parágrafo com scikit-learn (PEDREGOSA et al., 2011).

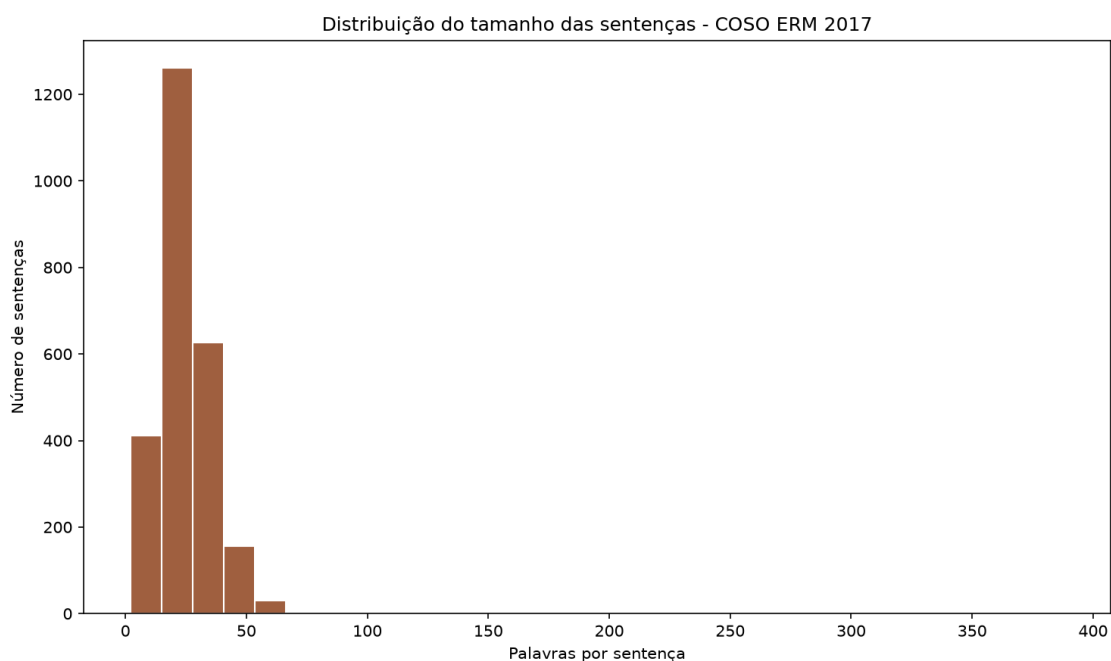


Figura 3 – Distribuição do número de palavras por sentença. A maior parte das sentenças concentra-se entre 15 e 35 palavras, informação relevante para calibrar o tamanho de chunk (segmento de texto) usado na indexação vetorial.

5.4 Estrutura temática: componentes e princípios do COSO ERM

Utilizando expressões regulares sobre o texto já limpo, foram identificados automaticamente **20 dos 20 princípios** oficiais do framework, distribuídos entre os cinco componentes do COSO ERM (Governança e Cultura; Estratégia e Definição de Objetivos; Desempenho; Revisão e Correção – do inglês *Review and Revision*; Informação, Comunicação e Relato). A Tabela 1 apresenta a lista extraída.

#	Princípio (título original em inglês)
1	Exercises Board Risk Oversight
2	Establishes Operating Structures
3	Defines Desired Culture
4	Demonstrates Commitment to Core Values
5	Attracts, Develops, and Retains Capable Individuals
6	Analyzes Business Context
7	Defines Risk Appetite
8	Evaluates Alternative Strategies
9	Formulates Business Objectives
10	Identifies Risk
11	Assesses Severity of Risk
12	Prioritizes Risks
13	Implements Risk Responses
14	Develops Portfolio View
15	Assesses Substantial Change
16	Reviews Risk and Performance
17	Pursues Improvement in Enterprise Risk
18	Leverages Information and Technology
19	Communicates Risk Information
20	Reports on Risk, Culture, and Performance

Tabela 1 – Princípios do COSO ERM 2017 extraídos automaticamente do corpus.

5.5 Preparação dos dados planejada para o pipeline de RAG

Além da limpeza descrita na seção 5.2, está planejado que a etapa de indexação do projeto aplique etapas adicionais de preparação antes de indexar o corpus em um banco vetorial (Chroma): (i) segmentação por seções usando padrões de capítulo/princípio; (ii) divisão em blocos (*chunks*) de até 400 tokens com sobreposição de 80 tokens, usando o tokenizador do modelo de embedding BAAI/bge-m3 (CHEN et al., 2024); (iii) deduplicação exata por hash SHA-256 do texto normalizado; e (iv) deduplicação semântica adicional, removendo chunks com similaridade de cosseno superior a 0,95 entre seus embeddings. Essas etapas complementam a análise exploratória e serão quantificadas (número de chunks gerados e removidos por deduplicação) na fase de implementação e avaliação do projeto.

6. Metodologia e Resultados Esperados

6.1 Arquitetura planejada da solução

A solução seguirá uma arquitetura de RAG (LEWIS et al., 2020), a ser implementada e avaliada ao longo do desenvolvimento do projeto, com as seguintes etapas planejadas:

- **Ingestão e indexação:** leitura dos documentos-fonte, segmentação, chunking por tokens, deduplicação e geração de embeddings (BAAI/bge-m3), a serem persistidos em um banco vetorial Chroma.
- **Recuperação:** busca por relevância marginal máxima (MMR) no Chroma, retornando um conjunto amplo de candidatos (fetch_k=50) para preservar diversidade antes do re-ranking.
- **Re-ranking:** um cross-encoder (BAAI/bge-reranker-v2-m3) reordenará os candidatos por relevância específica à pergunta, retendo os mais pertinentes.
- **Memória conversacional:** o histórico de interações será armazenado em uma coleção vetorial própria, com deduplicação semântica e limite máximo de itens, permitindo continuidade em perguntas de acompanhamento.
- **Geração:** o modelo Meta Llama 3.2 3B Instruct, quantizado em 4 bits (bitsandbytes), gerará a resposta condicionada ao contexto recuperado e à memória relevante, com instrução explícita de não extrapolar o contexto fornecido.
- **Estimativa de confiança:** cálculo da log-probabilidade média e da perplexidade da sequência gerada, como indicador auxiliar de confiança da resposta.
- **Avaliação do retriever:** métricas de Hit Rate, MRR (Mean Reciprocal Rank) e Precision@1, a serem calculadas sobre um conjunto de perguntas com trechos relevantes conhecidos.

6.2 Plano de trabalho para as próximas etapas

Nos próximos bimestres, o grupo pretende: (i) implementar as etapas de ingestão, indexação, recuperação e re-ranking descritas acima; (ii) consolidar um conjunto de perguntas de avaliação (com respostas/trechos de referência) para uso no módulo de avaliação do retriever; (iii) testar diferentes tamanhos de chunk e valores de *threshold* de similaridade, usando as estatísticas de tamanho de sentença obtidas na análise exploratória (Figura 3) como ponto de partida; (iv) implementar e testar a geração de respostas com o modelo local e o cálculo de perplexidade; e (v) documentar exemplos de uso do agente sobre perguntas de GRC.

6.3 Resultados esperados

Espera-se, ao final do projeto, um agente capaz de responder corretamente a perguntas objetivas sobre os 5 componentes e 20 princípios do COSO ERM 2017, sempre citando a fonte do trecho utilizado. Quantitativamente, espera-se obter, no módulo de avaliação do retriever, taxas de Hit Rate e MRR consistentemente superiores às obtidas por uma busca puramente lexical (baseline), validando o ganho da abordagem semântica combinada a re-ranking. Qualitativamente, espera-se que o indicador de perplexidade permita identificar respostas potencialmente pouco confiáveis, e que a citação de fontes torne o processo de verificação humana mais rápido do que a consulta manual ao documento original.

7. Referências

Trabalhos efetivamente citados ao longo do texto deste relatório:

CHEN, J. et al. BGE M3-Embedding: Multi-Lingual, Multi-Functionality, Multi-Granularity Text Embeddings Through Self-Knowledge Distillation. *arXiv preprint arXiv:2402.03216*, 2024.

COMMITTEE OF SPONSORING ORGANIZATIONS OF THE TREADWAY COMMISSION (COSO). *Enterprise Risk Management – Integrating with Strategy and Performance*. 2017.

FLORIDI, L.; COWLS, J. A Unified Framework of Five Principles for AI in Society. *Harvard Data Science Review*, v. 1, n. 1, 2019.

JI, Z. et al. Survey of Hallucination in Natural Language Generation. *ACM Computing Surveys*, v. 55, n. 12, p. 1–38, 2023.

LEWIS, P. et al. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. In: *Advances in Neural Information Processing Systems (NeurIPS)*, v. 33, 2020.

PEDREGOSA, F. et al. Scikit-learn: Machine Learning in Python. *Journal of Machine Learning Research*, v. 12, p. 2825–2830, 2011.

SALTON, G.; BUCKLEY, C. Term-Weighting Approaches in Automatic Text Retrieval. *Information Processing & Management*, v. 24, n. 5, p. 513–523, 1988.

UNESCO. *Recommendation on the Ethics of Artificial Intelligence*. Paris: UNESCO, 2021.

8. Bibliografia

Obras e documentações técnicas utilizadas como base teórica e metodológica para o desenvolvimento do projeto e a construção deste relatório, além das referências já citadas na seção anterior:

BIRD, S.; KLEIN, E.; LOPER, E. *Natural Language Processing with Python*. Sebastopol: O'Reilly Media, 2009. (documentação da biblioteca NLTK)

BRASIL. Projeto de Lei nº 2338/2023 (Marco Legal da Inteligência Artificial no Brasil). Senado Federal, 2023.

CHROMA. *Chroma Documentation*. Disponível em: <https://docs.trychroma.com>. Acesso em: 2026.

DETTMERS, T. et al. QLoRA: Efficient Finetuning of Quantized LLMs. *arXiv preprint arXiv:2305.14314*, 2023.

JURAFSKY, D.; MARTIN, J. H. *Speech and Language Processing*. 3. ed. (draft). Stanford University, 2024.

MANNING, C. D.; RAGHAVAN, P.; SCHÜTZE, H. *Introduction to Information Retrieval*. Cambridge: Cambridge University Press, 2008.

META AI. The Llama 3 Herd of Models. *arXiv preprint arXiv:2407.21783*, 2024.

REIMERS, N.; GUREVYCH, I. Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks. In: *Proceedings of EMNLP-IJCNLP*, 2019.